

Broken Function Level Authorization

Introduction

What is privilege escalation ?

Privilege escalation is a cyberattack technique where an attacker, having gained initial low-level access, exploits system vulnerabilities, bugs, or misconfigurations to elevate their permissions to a higher level (e.g., Administrator/Root). It is used to steal data, install malware, and gain full control

What is BFLA in API testing ?

BFLA allows unauthorized users to access functionality in API endpoints that should be restricted. The payloads used during these attacks often look completely legitimate and pass-through controls such as Web Application Firewalls.

Difference between BOLA and BFLA.

BOLA	BFLA
Unauthorized access to specific data objects. (mainly user objects)	Unauthorized use of API functions or actions
Modifying object identifiers (IDs, filenames, etc..)	Accessing restricted API endpoints, functions and HTTP methods.
More specific - It targets data access	Broader - can impact data and application functions.

What is the impact of this issue ?

- **Unauthorized access**
 - BFLA enables unauthorized entry to sensitive functionalities or resources.
- **Data Manipulation**
 - Exploiting broken function-level authorization allows attackers to tamper with data integrity.
- **Business Logic Abuse**
 - Broken function level authorization facilitates bypassing business rules, enabling attackers to misuse administrative functions.

Case Study

An e-commerce platform has an administrative panel to manage products, orders, and user accounts. Access to the full panel should only be available to users with the **administrator** role. A regular customer with the **basic_user** role can only view their own orders and update their profile information.

The website's API includes the following endpoints

- `/api/v1/admin/products/delete` (HTTP DELETE)
- `/api/v1/users/profile/update` (HTTP PUT)

The Vulnerability (BFLA)

The application has proper authorization checks for accessing the admin panel's user interface. However, the API endpoint for deleting products (**/api/v1/admin/products/delete**) only checks if the user is authenticated but fails to verify if the authenticated user has the necessary administrator role.

The attack

An attacker, logged in as a `basic_user`, notices the API call for product deletion in the application's network traffic when an administrator performs the action.

Seeing this, the attacker sends a direct response to the product deletion endpoint

```
DELETE /api/v1/admin/products/delete?product_id=12345
```

The API backend receives the request and gladly accepts it. This is due to the fact that the website is not doing proper validations. Resulting in a BLFA attack.

Mitigations

- Using the principle of least privilege
- Administrative function protection
- Input validation and Sanitization

Conclusion

Broken Function Level Authorization (BFLA) is a severe API vulnerability, enabling low-privilege users to execute restricted functions, as demonstrated in the e-commerce case study where a basic user could delete products.

Its impact includes unauthorized access, data integrity compromise, and abuse of business logic. Mitigating BFLA is crucial and requires strictly enforcing the **Principle of Least Privilege** and ensuring **role verification** at every restricted API endpoint.

References

<https://tcm-sec.com/bfla-broken-function-level-authorization/>

<https://salt.security/blog/api5-2023-broken-function-level-authorization>